

Module 1 — Understanding Defense

1.1 Assets, Vulnerabilities & Threats

Term	Definition
Assets	Anything of value to an organization (servers, infrastructure, data)
Vulnerabilities	Weaknesses in a system or design that could be exploited
Threats	Any potential danger to an asset

1.2 Asset Classification Criteria

Criterion	Description
Confidentiality	How sensitive is the data?
Value	What is the asset worth?
Time Sensitivity	How quickly does it lose value?
Access Rights	Who is authorized to use it?
Destruction Requirements	How must it be disposed of?

1.3 Asset Lifecycle

Stage	Action
Procurement	Acquire the asset
Deployment	Install and configure
Utilization	Operate and use
Maintenance	Maintain and update
Disposal	Retire and remove securely

1.4 Defense Models

Model	Description
Security Onion	Concentric layers — attacker must penetrate all layers sequentially
Security Artichoke	Overlapping leaves — attacker can target specific weak spots directly

1.5 Five Defense Strategies

Strategy	Description
Layering	Multiple protection barriers — no single point of failure
Limiting	Restrict access based on job requirements
Diversity	Vary defense mechanisms to prevent single-vendor failure
Obscurity	Hide system information from potential attackers
Simplicity	Ensure employees understand and can follow security configurations

1.6 Cybersecurity Operations Management

Area	Details
Configuration Management	Identify, control, and audit system baseline implementations
Documented Resources	Network maps, cabling diagrams, naming conventions, IP schemas
OS Hardening	Configure log files, auditing, change default credentials, implement access controls

1.7 Log Management (5 Stages)

Stage	Action
1	Generate — Create log entries from systems/events
2	Transmit — Send logs to centralized storage
3	Store — Retain logs securely
4	Analyze — Review for anomalies and incidents
5	Dispose — Securely delete per retention policy

1.8 Log Types

Type	What It Records
OS Logs	Authentication events, user activity
Application Security Logs	Malicious activity, compliance documentation

1.9 Protocol Analyzers (Packet Sniffers)

Use	Description
Traffic Logging	Capture and record network traffic
Problem Analysis	Diagnose network issues
Misuse Detection	Identify unauthorized usage
Intrusion Detection	Spot attack patterns
System Isolation	Identify and isolate compromised systems

1.10 Security Policy Types

Policy	Purpose
Company Policy	Defines mission, values, standards, and business rules
Employee Policy	Defines employee responsibilities and conduct
Security Policy	Defines how systems/data are protected (CIA)

1.11 Six Common Security Policy Types

Policy	Description
ID & Authentication	Identify and authenticate users
Password	Establish strong password rules
Acceptable Use (AUP)	Define acceptable use of systems and resources
Remote Access	Rules for accessing network remotely
Network Maintenance	Procedures for updates and changes
Incident Handling	Steps for responding to security incidents

1.12 BYOD Policy Requirements

Requirement	Description
Program Goals	Define purpose and scope
Eligible Employees	Who may participate
Supported Devices	Which devices are allowed
Access Levels	What resources can be accessed
Security Rights	IT rights to manage/wipe devices
Compliance	Regulatory requirements
Compromise Safeguards	Steps if device is lost/compromised

1.13 BYOD Best Practices

Practice	Description
Password Protection	Require strong device passwords
Wireless Control	Manage which networks device connects to
Software Updates	Keep OS and apps current
Data Backup	Regular backups of device data
Device Locator	Enable remote tracking
Antivirus	Install and maintain AV software
MDM	Mobile Device Management enrollment

1.14 Regulatory Compliance Examples

Regulation	Scope
HIPAA	Healthcare data protection
PCI-DSS	Payment card data security
GDPR	EU personal data privacy

Module 2 — System and Network Defense

2.1 Physical Security — Fencing

Height	Deterrent Level
1 meter	Casual deterrent only
2 meters	Too high to climb easily
2.5 meters	Provides limited delay

2.2 Biometrics

Type	Method
Fingerprint	Scans fingerprint ridges
Facial Recognition	Maps facial geometry
Iris Scan	Reads iris patterns
Retina Scan	Reads retinal blood vessels
Voice Recognition	Analyzes voice patterns

2.3 Biometric Error Types

Error	Definition	Risk Level
Type I — False Rejection	Legitimate user denied access	Lower risk
Type II — False Acceptance	Unauthorized user granted access	Most critical
CER	Crossover Error Rate — point where Type I = Type II	Accuracy metric

2.4 Surveillance Technologies

Technology	Purpose
CCTV	Video monitoring of physical spaces
RFID Asset Tracking	Track physical assets with radio tags
Security Guards	Human monitoring and response

2.5 Application Security — Dev Lifecycle

Stage	Description
Development	Code is written and tested
Staging	Pre-production testing environment
Production	Live environment used by end users

2.6 Secure Coding Techniques

Technique	Description
Normalization	Standardize data input to prevent injection
Stored Procedures	Pre-compiled DB queries to prevent SQL injection
Obfuscation	Make code harder to read/reverse engineer
Camouflage	Hide system details from attackers

2.7 Integrity Check — Hash Functions

Algorithm	Output Size	Status
MD5	128-bit	Broken — collision vulnerabilities
SHA-1	160-bit	Deprecated — weak
SHA-256	256-bit	Current standard — secure
SHA-512	512-bit	High security — larger output

2.8 Network Hardening — Protocol Replacements

Insecure Protocol	Port	Secure Replacement	Port
Telnet	23	SSH	22
FTP	21	FTPS / SFTP	990 / 22
HTTP	80	HTTPS	443
SNMPv1/v2	161	SNMPv3	161

2.9 Network Hardening — Services

Service	Security Measure
DHCP	DHCP Snooping — prevents rogue DHCP servers
DNS	DNSSEC — authenticates DNS responses
NTP	NTP Authentication — prevents time manipulation
ICMP	Filtering — limits ping-based reconnaissance

2.10 Network Segmentation

Method	Description
VLAN	Logical grouping of devices regardless of physical location
DMZ	Buffer zone between internal network and internet; hosts public-facing servers
Zero Trust	Never trust, always verify — continuous authentication required

2.11 Wireless Security Standards (Evolution)

Standard	Security Level	Notes
WEP	Broken	Easily cracked — do not use
WPA	Weak	Improved but still vulnerable
WPA2	Strong	Current minimum standard
WPA3	Strongest	Most secure — current best practice

2.12 EAP Authentication Frameworks

Framework	Description
EAP-TLS	Certificate-based — most secure
PEAP	Tunnels EAP inside TLS — uses server cert only
EAP-TTLS	Tunneled TLS — flexible inner auth
EAP-FAST	Cisco — uses Protected Access Credentials (PAC)

2.13 Cybersecurity Resilience

Concept	Description
N+1 Redundancy	One extra component beyond minimum needed
RAID	Redundant Array of Independent Disks — disk fault tolerance
Spanning Tree Protocol	Prevents network loops in switched networks
Honeypot	Single decoy system to lure and study attackers
Honeynet	Collection of honeypots forming a decoy network
DNS Sinkhole	Redirects malicious DNS queries to a controlled server

2.14 Code Signing

Concept	Description
Purpose	Verifies software hasn't been tampered with
Method	Developer signs code with private key; user verifies with public key

Module 3 — Access Control

3.1 Core Concept

Concept	Description
Access Control	Controlling who/what can access resources
Goal	Minimize risk via principle of least privilege

3.2 Access Control Models

Model	Description	Use Case
DAC	Discretionary — owner sets permissions	Flexible but lower security
MAC	Mandatory — system enforces labels	Military/government
RBAC	Role-Based — permissions tied to job role	Most common enterprise model
ABAC	Attribute-Based — uses user/resource/environment attributes	Most granular control
Rule-Based	Rules applied regardless of user identity	Firewalls, ACLs

3.3 AAA Framework

Component	Question	Description
Authentication	Who are you?	Verify identity
Authorization	What can you do?	Define permissions
Accounting	What did you do?	Log activity

3.4 Authentication Factors

Factor	Type	Examples
Knowledge	Something you know	Password, PIN
Possession	Something you have	Smart card, token, phone
Inherence	Something you are	Biometrics (fingerprint, iris)
MFA	2+ factors combined	Password + phone OTP

3.5 Physical vs. Logical Access Control

Type	Examples
Physical	Keycards, biometric scanners, security guards, fencing
Logical	Passwords, ACLs, firewalls, encryption

Module 4 — Access Control Lists (ACLs)

4.1 Core Concepts

Concept	Description
Definition	Rule sets applied to router interfaces filtering traffic based on packet headers
Processing	Top-down sequential — first match wins
Implicit Deny All	Any traffic NOT explicitly permitted is automatically blocked

4.2 Standard vs. Extended ACLs

Feature	Standard ACL	Extended ACL
Filters	Source IP only	Source IP + Destination IP + Protocol + Port
Granularity	Low	High
Number Range	1–99	100–199
Placement	Close to destination	Close to source

4.3 Wildcard Masks

Value	Meaning
0	Check this octet exactly
255	Ignore this octet
Formula	$255.255.255.255 - \text{Subnet Mask} = \text{Wildcard Mask}$

4.4 Inbound vs. Outbound Filtering

Direction	When Applied	Description
Inbound	Before routing decision	Applied to packets arriving into the interface
Outbound	After routing decision	Applied to packets leaving the interface

4.5 Example ACL Command

Element	Value
Command	<code>access-list 110 deny tcp 192.168.10.0 0.0.0.255 any eq 23</code>
Type	Extended (110)
Action	Deny
Protocol	TCP
Source	192.168.10.0/24
Destination	Any
Port	23 (Telnet)

Module 5 — Firewall Technologies

5.1 Core Concept

Concept	Description
Definition	Network security device monitoring/controlling traffic based on predefined rules
Position	Between trusted internal network and untrusted external network

5.2 Firewall Types

Type	How It Works	Speed	Notes
Packet Filtering	Inspects headers (IP, port, protocol)	Fastest	No state tracking
Stateful Inspection	Tracks connection state	Fast	Most common; knows if packet belongs to established session
Application Layer (Proxy)	Inspects full packet content at Layer 7	Slower	Most thorough; deep inspection
NGFW	Stateful + app awareness + IPS + DPI	Moderate	Most advanced

5.3 Filtering Methods

Method	Description
Packet Filtering	Checks IP, port, protocol in headers
Stateful Filtering	Tracks session state
Deep Packet Inspection (DPI)	Inspects full packet payload
URL Filtering	Blocks/allows based on web addresses
Application Filtering	Controls by application type

5.4 Defense-in-Depth Layers

Layer	Device	Role
1	Edge Router (R1)	First line — basic packet filtering
2	Firewall	Main checkpoint — stateful/NGFW inspection
3	Internal Router (R2)	Final layer — internal segmentation

5.5 Host-Based vs. Network-Based Firewalls

Type	Location	Protects
Host-Based	Installed on individual device	Single endpoint (e.g., Windows Defender Firewall)
Network-Based	Sits at network perimeter	Entire network segment

5.6 Firewall Best Practices

Practice	Why It Matters
Default Deny	Block all traffic unless explicitly permitted
Least Privilege	Only open ports/services that are needed
Regular Rule Audits	Remove outdated or overly permissive rules
Log All Traffic	Enables detection and forensic analysis
Layer with IPS/IDS	Firewall alone doesn't catch everything

Module 6 — Zone-Based Policy Firewalls (ZPF)

6.1 Core Concepts

Concept	Details
Definition	Firewall model assigning interfaces to security zones; policies applied between zones
vs. Classic Firewall	Classic = ACL on interface / ZPF = zone-to-zone policy (cleaner, scalable)
Default Behavior	Inter-zone traffic = DENIED by default unless policy explicitly permits
Same-Zone Traffic	Intra-zone = PERMITTED by default — no policy needed
Self Zone	The router itself; controls traffic TO/FROM the router (SSH, SNMP, routing protocols)

6.2 Zones

Zone	Description
Private (Inside)	Trusted internal LAN — highest trust
Public (Outside)	Untrusted internet — lowest trust
DMZ	Semi-trusted; hosts public-facing servers (web, mail, DNS)
Self	The router itself; managed separately

6.3 Policy Components

Component	Role
Zone	Logical grouping of interfaces with same trust level
Zone Pair	Defines direction of traffic (source zone → destination zone)
Class Map	Identifies/matches traffic (by protocol, ACL, etc.)
Policy Map	Defines action for matched traffic (inspect, pass, drop)
Service Policy	Applies the policy map to a zone pair

6.4 ZPF Actions

Action	Behavior
Inspect	Stateful — tracks connections, auto-allows return traffic
Pass	Allows traffic one direction only — no state tracking
Drop	Blocks traffic (equivalent to ACL deny)

6.5 Configuration Steps

Step	Command / Action
1. Create zones	<code>zone security INSIDE / zone security OUTSIDE</code>
2. Assign interfaces	<code>zone-member security INSIDE</code> under interface
3. Create class map	<code>class-map type inspect match-any</code>
4. Create policy map	<code>policy-map type inspect</code> with inspect/pass/drop
5. Create zone pair	<code>zone-pair security IN-OUT source INSIDE destination OUTSIDE</code>
6. Apply service policy	<code>service-policy type inspect</code> under zone pair

Module 7 — Cloud Security

7.1 Service Models

Model	Managed by Provider	Examples
IaaS	Hardware, virtualization, storage, networking	AWS EC2, Azure VMs
PaaS	IaaS + OS + middleware + runtime	Google App Engine, Heroku
SaaS	Everything — user just uses the app	Gmail, Office 365, Salesforce

7.2 Deployment Models

Model	Description
Public	Shared infrastructure, managed by provider
Private	Dedicated to one org — high security/compliance
Hybrid	Mix of public + private
Community	Shared by orgs with common needs (gov, healthcare)

7.3 Cloud Threats

Threat	Description
Data Breaches	Unauthorized access to cloud-stored data
Insecure APIs	Poorly secured interfaces attackers exploit
Account Hijacking	Stolen credentials used to access cloud resources
Insider Threats	Malicious/negligent provider or tenant employees
Shared Technology Vulns	Hypervisor flaws affecting multiple tenants
Data Loss	Accidental deletion, ransomware, provider failure

7.4 Cloud Security Controls

Control	Purpose
IAM	Controls who accesses what cloud resources
Encryption at Rest	Protects stored data (AES-256)
Encryption in Transit	Protects data in motion (TLS)
MFA	Adds second factor to cloud login
Security Groups / NACLs	Virtual firewall rules for cloud instances
CASB	Enforces security policies between users and cloud services
Shared Responsibility Model	Provider secures infrastructure; customer secures data/apps

7.5 Shared Responsibility Model

Layer	IaaS	PaaS	SaaS
Data	Customer	Customer	Customer
Applications	Customer	Customer	Provider
Runtime / OS	Customer	Provider	Provider
Virtualization	Provider	Provider	Provider
Physical Hardware	Provider	Provider	Provider

Module 8 — Cryptography

8.1 Core Concepts

Term	Definition
Plaintext	Original readable data
Ciphertext	Encrypted, unreadable data
Encryption	Plaintext → Ciphertext
Decryption	Ciphertext → Plaintext
Key	Value used by algorithm to encrypt/decrypt
Cipher	The algorithm itself

8.2 Encryption Types

Type	Keys	Speed	Use Case
Symmetric	1 shared key	Fast	Bulk data encryption
Asymmetric	Public + Private key pair	Slower	Key exchange, digital signatures

8.3 Symmetric Algorithms

Algorithm	Key Size	Notes
DES	56-bit	Outdated — easily cracked
3DES	112/168-bit	DES applied 3× — legacy
AES	128/192/256-bit	Current standard — fast, secure
RC4	Variable	Stream cipher — used in WEP (now broken)

8.4 Asymmetric Algorithms

Algorithm	Use
RSA	Encryption, digital signatures, key exchange
Diffie-Hellman (DH)	Secure key exchange over insecure channel
ECC	Smaller keys, same strength — mobile/IoT
DSA	Digital signatures only

8.5 Hash Functions

Algorithm	Output	Status
MD5	128-bit	Broken — collision vulnerabilities
SHA-1	160-bit	Deprecated — weak
SHA-256	256-bit	Current standard — secure
SHA-512	512-bit	High security — larger output

8.6 Cryptographic Goals

Goal	Tool
Confidentiality	Encryption (symmetric/asymmetric)
Integrity	Hash functions
Authentication	Digital signatures, certificates
Non-repudiation	Digital signatures (sender can't deny)

8.7 PKI Components

Component	Role
Certificate Authority (CA)	Issues and signs digital certificates
Digital Certificate	Binds public key to identity (X.509 standard)
CRL	Certificate Revocation List — revoked certs
OCSP	Real-time certificate status validation
Root CA	Top of trust hierarchy — self-signed
Intermediate CA	Issues end-entity certs on behalf of Root CA

Module 9 — Technologies and Protocols

9.1 VPN Types

Type	Description	Use Case
Site-to-Site VPN	Connects two networks permanently	Branch office to HQ
Remote Access VPN	Individual user connects to network	Work from home
SSL VPN	VPN over HTTPS (port 443)	Browser-based, no client needed
IPsec VPN	Encrypts at IP layer	Traditional corporate VPN
Split Tunneling	Only corporate traffic through VPN	Reduces bandwidth

9.2 IPsec Framework

Component	Options
Protocol	AH (integrity only) / ESP (integrity + encryption)
Mode	Transport (payload only) / Tunnel (full packet — VPNs)
Key Exchange	IKE using Diffie-Hellman
Encryption	AES, 3DES
Integrity	MD5, SHA

9.3 IDS vs. IPS

Feature	IDS	IPS
Position	Out-of-band (passive)	Inline (active)
Response	Alerts only	Detects AND blocks
False Positive Impact	Lower (just alerts)	Higher (can block legit traffic)
Deployment	SPAN/mirror port	Inline between router and switch

9.4 Detection Methods

Method	How It Works	Strength	Weakness
Signature-Based	Matches known attack patterns	Accurate for known threats	Misses zero-days
Anomaly-Based	Detects deviation from baseline	Catches unknown threats	High false positives
Policy-Based	Triggers on policy violations	Customizable	Requires manual policy creation

9.5 AAA Protocols

Protocol	Port	Transport	Notes
RADIUS	1812/1813	UDP	Combines auth + authz; encrypts password only
TACACS +	49	TCP	Separates AAA; encrypts full payload; Cisco proprietary
Diameter	3868	TCP/SCTP	Successor to RADIUS; used in mobile/4G

9.6 Secure vs. Insecure Protocols

Insecure	Port	Secure Replacement	Port
Telnet	23	SSH	22
FTP	21	FTPS / SFTP	990 / 22
HTTP	80	HTTPS	443
POP3	110	POP3S	995
IMAP	143	IMAPS	993
SMTP	25	SMTPS	465/587
SNMPv1/v2	161	SNMPv3	161
TFTP	69	SCP	22

Module 10 — Network Security Data

10.1 Types of Security Data

Data Type	Description	Example
Alert Data	Generated by IDS/IPS on detection	Snort: SQL injection alert
Session/Transaction Data	Summary of network conversations	NetFlow records
Full Packet Capture	Complete copy of all packets	Wireshark .pcap
Statistical Data	Aggregated traffic metrics	Bandwidth, connection counts
Log Data	Event records from systems/devices	Syslog, Windows Event Log

10.2 Log Sources

Source	Data Captured
Firewall Logs	Allowed/denied connections, src/dst IP, port
IDS/IPS Logs	Alerts, signatures triggered, severity
Server Logs	Auth attempts, errors, access records
DNS Logs	Domain lookups, failed resolutions
Proxy Logs	Web browsing activity, URLs visited
NetFlow	IP conversations: src/dst IP, port, bytes, duration

10.3 SIEM

Feature	Description
Definition	Aggregates, correlates, and analyzes logs from multiple sources
Log Aggregation	Collects from firewalls, IDS, servers, endpoints
Correlation	Links related events to detect attack patterns
Alerting	Triggers when rules/thresholds are met
Retention	Stores logs for compliance and forensics
Examples	Splunk, IBM QRadar, ArcSight, Microsoft Sentinel

10.4 Splunk Key Concepts

Concept	Description
Index	Where data is stored
SPL	Search Processing Language — Splunk's query language
Source Type	Defines format of incoming data
Event	Single log entry
Dashboard	Visual display of saved searches/reports
Alert	Automated notification when search condition is met
Lookup	Enriches events with external data (e.g., IP reputation)

10.5 Network Forensics Process

Step	Action
1. Identify	Detect incident via alerts/anomalies
2. Preserve	Capture and protect evidence (pcap, logs)
3. Collect	Gather data from all relevant sources
4. Examine	Filter and extract relevant data
5. Analyze	Correlate events, identify attacker TTPs
6. Report	Document findings, timeline, recommendations

10.6 Traffic Analysis Tools

Tool	Purpose
Wireshark	Full packet capture and analysis
tcpdump	Command-line packet capture
Snort	Open-source IDS/IPS with signature detection
Zeek (Bro)	Network traffic analysis framework
Nmap	Port scanning and host discovery
NetFlow Analyzer	Flow-based traffic analysis

Module 11 — Evaluating Alerts and Reports

11.1 Alert Classification

Classification	Definition	Action
True Positive (TP)	Real attack correctly detected	Respond immediately
True Negative (TN)	No attack, no alert	Normal — system working
False Positive (FP)	Alert triggered, no real attack	Tune rules to reduce noise
False Negative (FN)	Real attack NOT detected	Most dangerous — review signatures

11.2 Alert Triage Process

Step	Action
1. Receive Alert	Alert from IDS/IPS/SIEM
2. Classify	TP / FP / TN / FN
3. Prioritize	Critical → High → Medium → Low
4. Investigate	Examine logs, pcap, correlated events
5. Escalate	Confirmed threat → Tier 2 / IR team
6. Document	Record in ticketing system
7. Remediate	Contain, eradicate, recover

11.3 Incident Severity Levels

Level	Description	Response Time
Critical (P1)	Active breach, data exfiltration, ransomware	Immediate
High (P2)	Confirmed attack, significant risk	< 1 hour
Medium (P3)	Suspicious activity, policy violation	< 4 hours
Low (P4)	Informational, minor anomaly	< 24 hours

11.4 Security Report Types

Report Type	Purpose	Audience
Executive Summary	High-level security posture overview	C-suite, management
Incident Report	Detailed account of a specific event	Security team, legal
Vulnerability Report	Discovered vulns + risk ratings	IT/Security team
Compliance Report	Evidence of regulatory adherence (PCI-DSS, HIPAA)	Auditors, management
Trend Report	Attack patterns over time	Security analysts

11.5 Key Security Metrics

Metric	What It Measures
MTTD	Mean Time to Detect — avg time from attack start to detection
MTTR	Mean Time to Respond — avg time from detection to containment
False Positive Rate	% of alerts that are not real threats
Alert Volume	Total alerts in a period
Patch Compliance Rate	% of systems with current patches
Vulnerability Density	Number of vulns per system/asset

11.6 CVSS Score Ranges

Score	Severity
0.0	None
0.1 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10.0	Critical

11.7 Threat Intelligence Sources

Source	Description
OSINT	Open-source intelligence (public threat feeds, news)
ISAC	Information Sharing and Analysis Centers (sector-specific)
MITRE ATT&CK	Framework of adversary TTPs
CVE Database	Common Vulnerabilities and Exposures — public vuln list
VirusTotal	File/URL reputation checking
STIX/TAXII	Standards for sharing threat intelligence data